Modelovanje pretnji na imaginarnom softverskom sistemu *MegaTravel*

Cilj sledećih zadataka je izvođenje modeliranja pretnji na imaginarnom softverskom sistemu koji vodi međunarodna korporacija specijalizovana za pružanje turističkih usluga.

Zadatak 1: Ko bi želeo da napadne MegaTravel i zašto?

Napadač	**Veština**	**Pristup**	**Cilj**
Kibernetički kriminalci	Visoka	Eksterni	Finansijska korist
Napadači motivisani ideologijom ili protestom (*Hacktivist*)	Srednja	Eksterni	Narušavanje reputacije, DDoS, objavljivanje internih podataka
Konkurencija	Niska/Srednja/Visoka	Eksterni, potencijalno interni	Krađa poslovnih tajni, cenovnih strategija, baze klijenata
Script Kiddies	Niska	Eksterni	Zabava
Istraživači	Visoka	Eksterni	Novčana nagrada, reputacija
Insider	Niska/Srednja/Visoka	Interni	Finansijska korist, osveta, sabotaža

Tabela 1 - Klase napadača

Zadatak 2: Šta je vredno zaštititi u MegaTravel sistemu?

Zbog imovine, poput:

1. **Lični podaci klijenta (*Personally Identifiable Information*, PII)**
    - Izloženost: Klijenti, zaposleni, partneri
    - CIA:
        - Poverljivost: Visoka
        - Integritet: Srednji
        - Dostupnost: Niska
    - Uticaj: Gubitak poverenja klijenta, reputacijska šteta, tužbe

2. **Platni podaci**
    - Izloženost: Klijenti, payment procesori, finansijsko osoblje
    - CIA:
        - Poverljivost: Visoka
        - Integritet: Visok
        - Dostupnost: Srednja
    - Uticaj: Direktna finansijska šteta, tužbe, gubitak licence za procesiranje plaćanja

3. **Putni planovi i rezervacije**
    - Izloženost: Klijenti, zaposleni, partneri
    - CIA:
        - Poverljivost: Visoka
        - Integritet: Visoka
        - Dostupnost: Visoka
    - Uticaj: Privatnost klijenta ugrožena, potencijalna fizička opasnost po klijante
4. **Poslovni podaci**
    - Izloženost: Partneri, finansijsko osoblje
    - CIA:
        - Poverljivost: Visoka
        - Integritet: Nizak
        - Dostupnost: Niska
    - Uticaj: Narušavanje poslovnih odnosa sa partnerom, finansijska šteta
5. **Baza podataka**
    - Izloženost: Administratori, bekend aplikacija, IT osoblje
    - CIA:
        - Poverljivost: Visoka
        - Integritet: Visoka
        - Dostupnost: Visoka
    - Uticaj: Kompromituje sve podatke odjednom, potpuni operativni kolaps
6. **Podaci zaposlenih**
    - Izloženost: HR osoblje, IT administratori
    - CIA:
        - Poverljivost: Visoka
        - Integritet: Srednji
        - Dostupnost: Niska
    - Uticaj: Tužbe od strane zaposlenih, socijalni inženjering napadi
7. ***Backup* sistemi**
    - Izloženost: IT administratori, DevOps osoblje
    - CIA:
        - Poverljivost: Visoka
        - Integritet: Visoka
        - Dostupnost: Visoka
    - Uticaj: Nemogućnost oporavka od napada
8. **Autentifikacioni sistem**
    - Izloženost: Svi korisnici

- CIA:
    - Poverljivost: Visoka
    - Integritet: Visok
    - Dostupnost: Visoka
- Uticaj: Padom ovog sistema ostatak postaje nedostupan ili kompromitovan, što znači da napadač može preuzeti bilo koji nalog

9. ***Web* aplikacija / API**
    - Izloženost: Svi korisnici
    - CIA:
        - Poverljivost: Visoka
        - Integritet: Visoka
        - Dostupnost: Visoka
    - Uticaj: Nedostupnost servisa, manipulacija podacima, ulazna tačka za dublje napade
10. **Interni sistemi komunikacije**
    - Izloženost: Zaposleni, IT osoblje
    - CIA:
        - Poverljivost: Visoka
        - Integritet: Srednji
        - Dostupnost: Niska
    - Uticaj: Curenje internih informacija, socijalni inženjering, špijunaža

Zadatak 3: Površina napada

Korisnici sistema:

1. **Ljudski korisnici**
   - Klijenti (registrovani i anonimni posetioci)
   - Zaposleni
   - Administratori sistema
   - HR i finansijsko osoblje

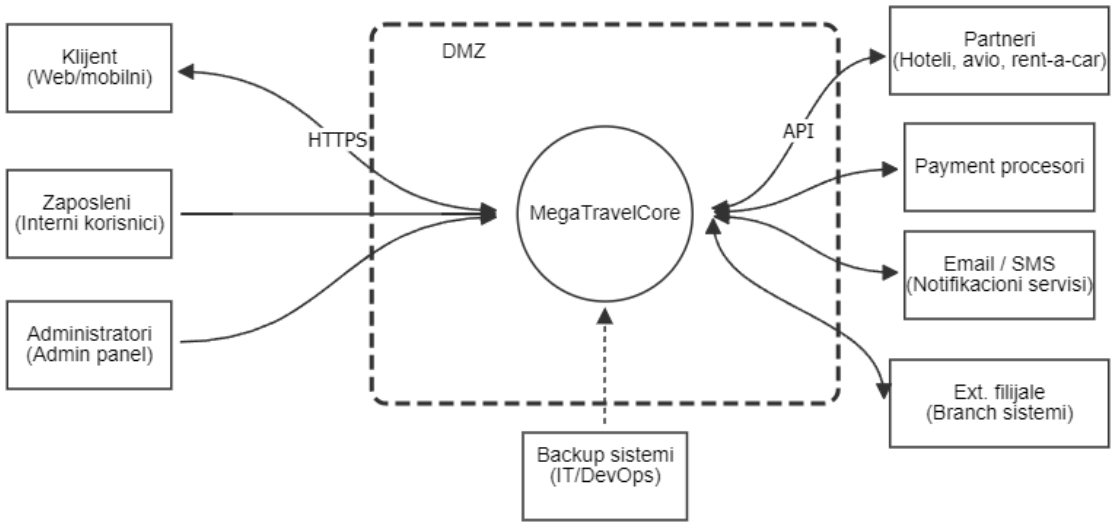
2. **Eksterni sistemi:**
   - Partneri (hoteli, avio-kompanije, rent-a-car servisi)
   - Payment procesori
   - Treće strane za slanje emailova/SMS-ova
   - Mape i geolokacijski servisi
   - Sistemi eksternih filijala

Ulazna tačka	Ko je koristi
Web aplikacija (HTTPS)	Klijenti, anonimni korisnici
Mobilna aplikacija (API)	Klijenti

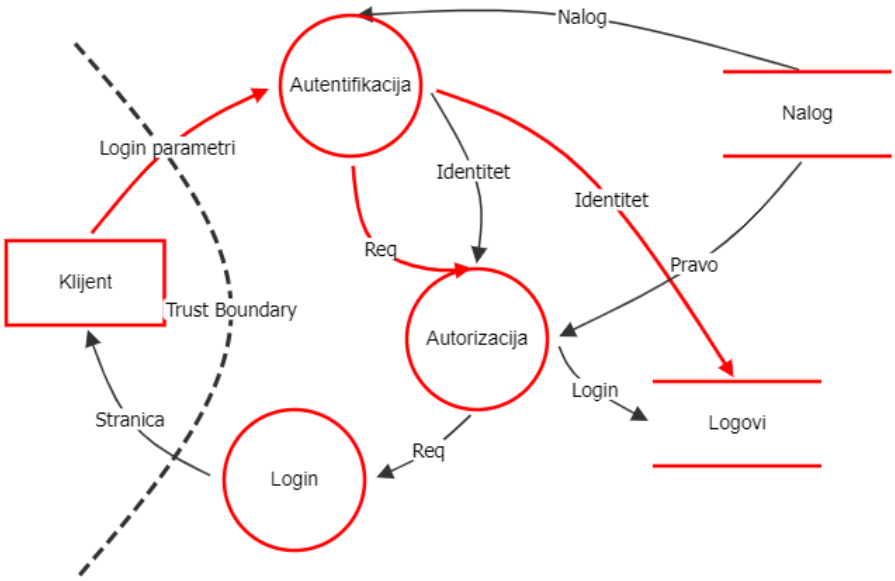
Admin panel	Administratori
Partner API	Hoteli, avio-kompanije, rent-a-car
Payment gateway integracija	Payment procesori
Email / SMS service	Treće strane
Interni chat sistemi	Zaposleni
Fizički pristup (sedišta, filijale)	Zaposleni, posetioci
Baza podataka (interni pristup)	Backend aplikacija, administratori
Backup sistemi	DevOps, IT administrator

Tabela 2 - Površina napada

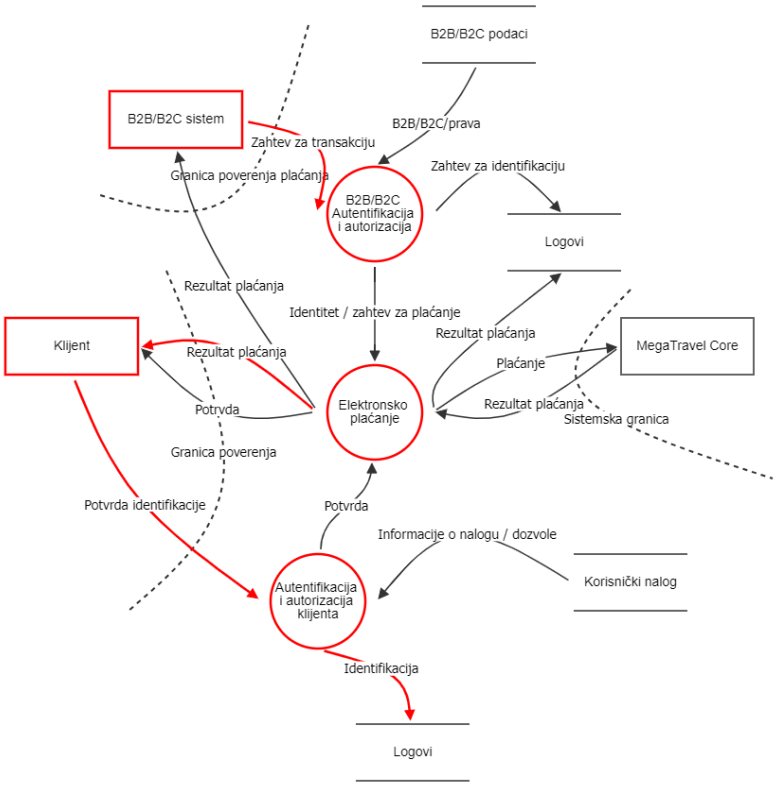
Zadatak 4:



Slika 1 - Kontekst dijagram



Slika 2 - Dijagram toka podataka za Login



Slika 3 - Dijagram toka podataka za Elektronsko plaćanje

Zadatak 5: Identifikacija pretnji

Login (Slika 2):

Naziv	Tip	Opis	Mere ublažavanja
Malver simulira akcije tastature	Lažno predstavljanje	Malver na klijentskom uredaju simulira korisnikove akcije.	Implementirati mehanizme detekcije automatizovanog unosa (npr. behavioral analysis); koristiti MFA i zaštitu od botova.
Malver simulira slanje paketa klijenta	Lažno predstavljanje	Malver šalje pakete u ime korisnika.	Koristiti autentifikaciju zahteva (tokeni; potpisivanje zahteva); TLS i validaciju sesije.
Malver lažira korisnicke operacije	Lažno predstavljanje	Malver lažira korisnicku operaciju na višem nivou.	Implementirati verifikaciju kriticnih akcija (dodatna autentifikacija; audit logovi; potvrde akcija).
Nelegalno pribavljen sertifikat	Lažno predstavljanje	Napadač koristi legalno pribavljen ili falsifikovan sertifikat.	Koristiti robusnu validaciju sertifikata (pinning; provera lanca poverenja).
Klijent sadrži ugraden maliciozni program	Izmena podataka	Malver menja memoriju pregledača ili manipuliše korisnickim unosom.	Primena zaštite klijentskog okruženja i provera integriteta (sandboxing; secure input).
Osetljive informacije bez bezbednog rukovanja	Otkrivanje informacija	Osetljivi podaci se cuvaju lokalno i mogu procureti.	Ne skladištiti osetljive podatke lokalno bez enkripcije; koristiti secure storage.
Bezbednosne ranjivosti klijenta	Eskalacija privilegija	Klijentske komponente imaju ranjivosti koje omogucavaju udaljene napade.	Redovno ažurirati operativni sistem i pregledac; primenjivati bezbednosne zakrpe.
Izmena internog zahteva	Eskalacija privilegija	Izmena sadržaja internog zahteva radi zaobilaženja provera autorizacije.	Digitalno potpisivati interne zahteve ili koristiti bezbedne interne tokene

Prekid toka zapisa logova	Poricanje	Prekid ili ometanje ovog toka podataka dovodi do nedostajucih log zapisa.	Implementirati mehanizme garantovane isporuke audit logova.
Bezbednosni mehanizam nije savršen	Otkrivanje informacija	Nedostatak bezbednosti kanala ili slaba zaštita poruka omogućava presretanje podataka.	Primeniti jake protokole enkripcije (TLS 1.3) na ovoj granici.
Bezbednost lozinki i brute force napadi	Lažno predstavljanje	Napadaci pogadaju ili brute-force napadaju parametre za prijavu.	Implementirati ogranicenje broja pokušaja; zakljucavanje naloga; i jake politike lozinki.
Malver menja zahtev	Izmena podataka	Malver menja korisnicke podatke zahteva pre nego što stignu do servera.	Koristiti mutual TLS i potpisivanje zahteva.
Presretanje parametara za prijavu	Otkrivanje informacija	Malver krade osetljive podatke ili lažni sajt obmanjuje korisnika (phishing).	Koristiti bezbedan prenos (HTTPS); anti-phishing mere; i višefaktorsku autentifikaciju.
Preopterecenje kanala	Uskracivanje usluge	Neispravni parametri prijave uzrokuju veliku potrošnju CPU/memorije.	Implementirati WAF i strogu validaciju/ogranicenje velicine ulaza.
Ranjivost autentifikacije servera	Lažno predstavljanje	Ranjivost autentifikacije servera koja se može zaobici.	Sprovesti bezbednosni pregled koda i koristiti pouzdane biblioteke za autentifikaciju.
Mehanizam sesije nije savršen	Lažno predstavljanje	Nedostatak timeout-a sesije ili provere stanja.	Implementirati stroge timeout-ove sesije i validaciju.
Zastoj ili pad servera	Uskracivanje usluge	Neispravni parametri ili veliki broj paralelnih operacija uzrokuju zastoj ili pad.	Ogranicavanje resursa i pravilno rukovanje greškama.
Ranjivosti servera	Eskalacija privilegija	Ranjivosti u kodu procesa autentifikacije	Kontinuirano skeniranje ranjivosti i

		omogucavaju eskalaciju privilegija.	penetraciono testiranje.
Eskalacija privilegija putem ranjivosti servera	Eskalacija privilegija	Napadač koristi slabosti servera da zaobide autorizaciju.	Primena principa najmanjih privilegija i stroga RBAC kontrola.
Izmena logike autorizacije	Izmena podataka	Zlonamerna izmena memorije ili konfiguracije menja dozvole.	Koristiti potpisane i neizmenjive konfiguracije; zaštitu memorije.
XSS ranjivosti na serveru	Eskalacija privilegija	XSS ranjivosti na serverskoj strani stranice za prijavu.	Sanitizovati i enkodirati izlaz; koristiti Content Security Policy (CSP).
Izmena podataka	Izmena podataka	Napadac menja ili briše logove da prikrije tragove.	Implementirati WORM skladištenje logova.
Neadekvatni log zapisi	Poricanje	Nedostatak ili nepotpuni log zapisi omogucavaju poricanje aktivnosti.	Obezbediti sveobuhvatno i kontinuirano logovanje.
Otkrivanje informacija iz logova	Otkrivanje informacija	Neovlašcen pristup logovima otkriva osetljive podatke.	Enkriptovati logove i ograniciti pristup.
Izmena podataka naloga	Izmena podataka	Napadac menja stanja naloga ili privilegije direktno u bazi.	Stroga kontrola pristupa; nadzor aktivnosti baze; i enkripcija.
Izlaganje podataka naloga	Otkrivanje informacija	Proboj baze podataka otkriva korisnicke podatke i licne informacije.	Enkriptovati osetljive podatke i koristiti jake hash funkcije (npr. Argon2).
Preopterecenje baze	Uskracivanje usluge	Preopterecenje baze onemogucava legitimne autentifikacije.	Klastrovanje baze; optimizacija upita; i pooling konekcija.

Tabela 3 - Identifikacija pretnji login sistema

Elektronsko plaćanje (Slika 4):

Naziv	Tip	Opis	Mere ublažavanja
Lažno predstavljanje identiteta drugog korisnika	Lažno predstavljanje	Nelegalno pribavljen sertifikat; nebezbedna autentifikacija; kompromitovane lozinke; brute force; neadekvatan mehanizam sesije.	Snažna autentifikacija; MFA; upravljanje sesijama.
Lažno predstavljanje klijenta u komunikaciji	Lažno predstavljanje	Malver simulira akcije tastature; šalje poruke u ime klijenta; lažira korisničke operacije.	Zaštita klijentskog okruženja; detekcija anomalija.
Klijent sadrži maliciozni program	Izmena podataka	Malver menja korisničke zahteve; memoriju pregledača; ili poruke koje se šalju/primaju.	Potpisivanje zahteva; anti-malware rešenja.
Korisnici poriču izvršene transakcije	Poricanje	Nedostatak mehanizma potpisivanja transakcija.	Digitalni potpisi za transakcije.
Malver krade osetljive podatke korisnika	Otkrivanje informacija	Malver krade lozinke putem keylogger-a; snimaka ekrana; ili memorije pregledača.	Bezbedan unos; virtuelne tastature.
Osetljive informacije bez bezbednog rukovanja	Otkrivanje informacija	Osetljivi podaci se čuvaju lokalno; ključ za enkripciju je na klijentu; privremeni fajlovi se ne brišu.	Onemogućiti lokalno keširanje osetljivih podataka.
Lažni sajt za krađu korisničkih podataka	Otkrivanje informacija	Korisnik je žrtva phishing napada.	Obuka protiv phishing-a; vizuelni indikatori bezbednosti.
E1 - Ranjivosti klijenta	Eskalacija privilegija	Ranjivosti kontrole klijenta; kernel drajvera; komponenti; cross-domain napadi.	Upravljanje zakrpama; bezbednosne politike pregledača.
B2B/B2C je lažna stranica	Lažno predstavljanje	Lažno predstavljanje domena; URL-a;	DNSSEC; stroga validacija domena.

		sadržaja; ARP spoofing; kompromitovan framework.	
B2B/B2C je lažna stranica (sertifikati)	Lažno predstavljanje	Nelegalno pribavljen sertifikat ili nebezbedna autentifikacija između partnera.	Mutual TLS (mTLS) sa partnerima.
B2B/B2C stranica sadrži malver	Izmena podataka	Malver menja zahteve transakcija koji dolaze od partnera.	Provera integriteta zahteva (HMAC).
B2B/B2C stranica pod kontrolom napadača	Izmena podataka	Kompromitovani partner šalje zlonamerni saobraćaj.	Stroga validacija API šema.
B2B/B2C partner poriče transakciju	Poricanje	Nedostatak validnog potpisa ili nepotpuni log zapisi.	Tokeni za neporicanje; sveobuhvatno logovanje.
Ranjivosti servera (XSS i dr.)	Eskalacija privilegija	Server ima XSS ili druge ranjivosti koje omogućavaju eskalaciju privilegija.	Bezbedno programiranje; WAF.
Ranjivosti servera (obrada plaćanja)	Eskalacija privilegija	Ranjivosti u logici obrade plaćanja.	Stroga validacija ulaza; parametrizovani upiti.
Ranjivosti servera (autentifikacija)	Eskalacija privilegija	Ranjivosti u logici autentifikacije klijenta.	Korišćenje pouzdanih autentifikacionih okvira.
Bezbednosni mehanizam nije adekvatan	Otkrivanje informacija	Nedostatak zaštite poruka ili kanala; slaba bezbednost komunikacije.	Primena jake TLS enkripcije.
Preopterećenje kanala	Uskraćivanje usluge	Neispravni parametri; veliki broj paralelnih operacija; SYN/HTTP flood.	Rate limiting; WAF; validacija parametara.
Narušen integritet poruka	Uskraćivanje usluge	Gubitak integriteta poruka dovodi do grešaka u obradi.	Potpisivanje poruka i validacija integriteta.
Bezbednosni mehanizam nije	Otkrivanje informacija	Slaba ili nepostojeća zaštita kanala izlaže	Primena jake TLS enkripcije.

adekvatan (identifikacija)		podatke o identifikaciji.	
Preopterećenje kanala (potvrde)	Uskraćivanje usluge	Veliki broj zahteva za potvrdu ili neispravni parametri.	Ograničavanje protoka i sanitizacija ulaza.
Narušen integritet poruka (potvrde)	Uskraćivanje usluge	Kompromitovan integritet poruka za potvrdu.	Potpisivanje poruka.
Preopterećenje (logovi)	Uskraćivanje usluge	Neispravni parametri uzrokuju pad ili zastoj obrade logova.	Asinhrono logovanje; robusno rukovanje greškama.
Neadekvatni log zapisi (identifikacija)	Poricanje	Nedostatak ili nepotpuni log zapisi tokom identifikacije.	Obezbediti garantovano beleženje logova.
Bezbednosni mehanizam nije adekvatan (rezultat plaćanja)	Otkrivanje informacija	Slaba zaštita kanala omogućava presretanje rezultata plaćanja.	Korišćenje bezbednog prenosa (TLS 1.2+).
Narušen integritet poruka (rezultat plaćanja)	Uskraćivanje usluge	Integritet poruke o rezultatu plaćanja je kompromitovan.	Digitalno potpisivanje odgovora.

Tabela 3 - Identifikacija pretnji sistema za elektronsko plaćanje